ランサムウェアの進化とAI防衛の現在地，そして未来へのロードマップ

佐野 泰之[1,a)]　須崎 有康[1,b)]

概要：近年，ランサムウェアは個人や組織，重要インフラに対して甚大な被害をもたらす主要なサイバー脅威となっている．従来の攻撃は主にファイルを暗号化して身代金を要求する暗号型やシステムを制限するロッカー型が中心であったが，ビットコインに代表される匿名性の高い暗号資産の普及やRaaS (Ransomware-as-a-Service) の確立を機に，特定の組織を狙う標的型 (Big Game Hunting) へと移行した．さらに，攻撃プラットフォームはWindows環境にとどまらず，重要データが保管されるLinuxサーバーへと急速に拡大している．これに伴い，攻撃モデルは暗号化の実行前に機密データを窃取し，暴露をちらつかせて脅迫する二重脅迫（データ持ち出し）へと大きく移行している．本稿では，1989年から現在に至るランサムウェアの進化を5大段階（1989年，2004〜2006年，2007〜2012年，2013〜2019年，2019年〜現在）として整理し，最新の防衛研究，特に機械学習 (ML) と深層学習 (DL) を用いた動的解析による早期検知技術や，OSの暗号化APIをフックしてセッション鍵を保護するPayBreak，CSPRNGの予測可能性を突く鍵特定といったデータ復旧・救出手法について包括的なサーベイを提供する．一方で，今後の実用的な防衛に向けた技術的課題として，AIモデルの実運用における概念ドリフトや，検知を回避しようとする敵対的機械学習へのレジリエンス（強靭性）強化が急務である．本稿は，これらを踏まえ，ランサムウェア対策を攻撃自体の防御（侵入防止・暗号化防止）と被害の影響の最小化（持ち出し検出・横展開抑制・復旧）に大別して構造化する．そして，ネットワーク内の横展開を防ぐマイクロセグメンテーション，汚染のないクリーンな世代への遡及を可能とする検証可能な戻せるバックアップといったイノベーションと，組織のビジネス・法規制遵守を統合した包括的なセキュリティリスク管理 (GRC) の実装・相互検証に向けた，実践的な多層防御のロードマップを提示する．

キーワード：ランサムウェア，二重脅迫（データ持ち出し），機械学習・深層学習，多層防御，敵対的機械学習，概念ドリフト，ガバナンス・リスク・コンプライアンス（GRC）

The Evolution of Ransomware, the Current State of AI Defense, and a Future Roadmap

Yasuyuki Sano[1,a)]　Kuniyasu Suzaki[1,b)]

Abstract: In recent years, ransomware has become a major cyber threat to individuals, organizations, and critical infrastructure. While early attacks mainly relied on file encryption or system locking, the spread of cryptocurrencies and Ransomware-as-a-Service (RaaS) has driven a shift toward targeted “Big Game Hunting.” Attack platforms have also expanded from Windows to Linux servers, accompanied by the rise of double extortion, in which sensitive data are stolen before encryption and victims are threatened with disclosure. This paper reviews the evolution of ransomware from 1989 to the present in five major phases and surveys recent defensive research. It focuses on early detection using machine learning (ML) and deep learning (DL), as well as recovery techniques such as PayBreak, which preserves encryption keys by hooking cryptographic APIs, and key-recovery methods exploiting CSPRNG predictability. This paper also highlights challenges including concept drift and adversarial machine learning. It categorizes defenses into attack prevention and impact mitigation, and proposes a multilayered roadmap combining microsegmentation, verifiable rollback-capable backups, and Governance, Risk, and Compliance (GRC) to improve both technical resilience and organizational security risk management.

Keywords: Ransomware, Double Extortion (Data Exfiltration), Machine Learning and Deep Learning, Multi-layered Defense, Adversarial Machine Learning, Concept Drift, Governance, Risk, and Compliance (GRC)

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

1. はじめに

近年，ランサムウェアは個人や組織，重要インフラに対して甚大な被害をもたらす主要なサイバー脅威である．従来の攻撃はファイルを暗号化する暗号型やシステムを制限するロッカー型が中心であった．しかし，追跡困難なビットコインに代表される暗号資産の普及や RaaS (Ransomware-as-a-Service) の確立を機に，特定の組織を狙う標的型 (Big Game Hunting) へと移行した [1]．さらに，昨今では Windows のみならず，重要データが保管される Linux サーバーへの標的拡大も確認されている．これに伴い，ランサムウェアの攻撃モデルは，ファイルを暗号化する前に機密データを窃取し，身代金を支払わなければ暴露サイトで公開すると脅す二重脅迫（データ持ち出し）へと大きく移行している [2]．データが一度外部に流出すれば，たとえバックアップからシステムを完全に復元できたとしても，情報漏洩による不可逆的な社会的・法的損害を免れることは困難である．

これに対し，従来のシグネチャベースの検知に代わり，機械学習 (ML) や深層学習 (DL) を用いた動的解析に基づく早期検知が現在の防衛手法となっている [3]．また，OS の暗号化 API をフックしてセッション鍵を保管する PayBreak 等の鍵傍受技術 [4] や，疑似乱数生成器 (CSPRNG) の脆弱性を突いてセッション鍵を推測・回収する復旧技術 [5] も実証されてきた．しかし，防衛側がこれらのエンドポイント検知や暗号化防止策を講じる一方で，実際の攻撃はデータ持ち出し，ネットワーク内での横展開（ラテラルムーブメント），さらにはバックアップの破壊や汚染といった復旧妨害を組み合わせる多段階のシーケンスへと高度化しており，単一のエンドポイント対策のみに依存するアプローチでは十分ではないという限界が露呈している [2]．

すなわち，現在の学術研究開発の大部分が依然としてファイル暗号化の阻止に注力している一方，実際の脅威はデータ持ち出しや復旧妨害へと多角化しており，研究上の重点と実際の脅威との間に重大な技術的ギャップが生じている [2]．特に，暗号化前のデータ流出は暗号化の遮断やバックアップからの復旧だけでは解消できない不可逆的な被害をもたらすため，不審な通信，データ圧縮，大容量転送の監視・遮断といった持ち出し防止策を並行して強化することが重要である．また，実運用における機械学習検知においては，時間の経過に伴う概念ドリフトや，検知を巧妙に回避する敵対的機械学習へのレジリエンス（強靭性）強化も同時に克服すべき技術的課題である [3]．

本稿の目的は，これらの現状を踏まえ，進化し続けるランサムウェアに対する包括的なサーベイを提供することである．我々は，1989 年から現在に至る歴史的変遷と分類を整理し，最新の ML/DL 検知や鍵回復技術の現状を評価する．その上で，ランサムウェア対策を攻撃自体の防御（侵入防止・暗号化防止）と被害の影響の最小化（持ち出し検出・横展開抑制・復旧）に大別し，防衛側と攻撃者の対応関係を体系的に構造化する．そして，ネットワーク内の横展開を動的に封じ込めるマイクロセグメンテーション，汚染のないクリーンな世代への遡及を可能にする検証可能な戻せるバックアップ，およびこれら技術・人・プロセスを組織のビジネス要件や法規制に準拠させる包括的なガバナンス・リスク・コンプライアンス (GRC) フレームワークへと統合し，より実践的な多層防御のロードマップを提示する．

2. ランサムウェアの進化と分類

ランサムウェアは，35 年以上にわたり攻撃手法や収益モデルを巧妙に変化させながら進化を遂げてきた [1]．本章では，ランサムウェアの歴史的な進化の軌跡を振り返り，その多角的な分類および典型的な攻撃チェーン（キルチェーン）について，技術的な観点から詳述する．

2.1 進化の軌跡

ランサムウェアは，図 1 のとおり，その出現から現在に至るまで攻撃と防御を繰り返し，技術的な進化やビジネスモデルの変遷に応じて大きく 5 つの段階に分類される．

2.1.1 1989 年

ランサムウェアの歴史は，1989 年にフロッピーディスクを介して物理的に配布された AIDS Trojan から始まった [1]．このマルウェアは，独自の対称暗号アルゴリズムを使用して C: ドライブのファイル名や特定のディレクトリを暗号化し，復号のための金銭を私書箱宛てに郵送するよう要求するものであった．しかし，暗号鍵が被害者側のローカル内に保存される等の実装上の脆弱性があり，再構成によって容易に解析・復旧が可能であった [1]．

2.1.2 2004〜2006 年

2000 年代半ばに入ると，暗号技術の進化に伴い本格的な暗号型ランサムウェアが台頭した [3]．この段階における最大の技術的転換点は，RSA 等の非対称暗号（公開鍵暗号）の本格的な導入である [1]．攻撃者は，自分のみが持つ秘密鍵を自身のサーバーに隠蔽し，公開鍵のみをマルウェアに埋め込んでファイルの暗号化を実行するため，攻撃者の秘密鍵なしに現実的な計算時間でデータを復号することは困難となった [3]．この時期の攻撃は，不特定多数の個別ユーザーが主なターゲットであった．

2.1.3 2007〜2012 年

2000 年代後半から 2010 年代初頭にかけては，暗号化を伴わないスクリーンロッカーや偽警告を伴う手口（WinLock

[1] 情報セキュリティ大学院大学
Graduate School of Information Security, Institute of Information Security
[a)] mgs264502@iisec.ac.jp
[b)] suzaki@iisec.ac.jp

© 2026 Information Processing Society of Japan

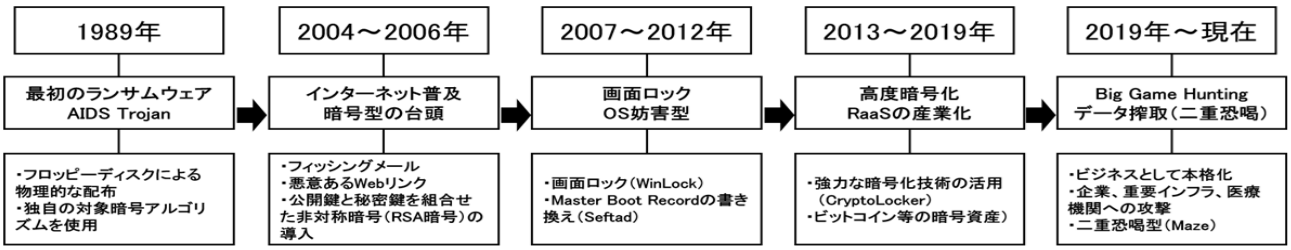


図 1: ランサムウェアの進化

等）が流行した [6]．これらのマルウェアは，OS やブラウザの操作画面をロックし，偽の法執行機関（FBI や警察等）の警告画面を強制表示させてユーザーを畏怖させ，罰金名目で金銭を要求する [1]．暗号化技術を使用しないため，技術的な破壊力は低いものの，ユーザーの心理的な隙を突くソーシャルエンジニアリング的アプローチが目立った時代である [1]．

2.1.4 2013～2019 年

この段階は，現代的なランサムウェアのエコシステム（ビジネスモデル）が完全に確立・産業化した時期である [1]．まず 2013 年に登場した CryptoLocker は，RSA-2048 と AES を組み合わせたハイブリッド暗号化を導入し，高速かつ復号が困難な暗号化プロセスを自動化させた [4]．さらに，決済手段に追跡困難なビットコインに代表される暗号資産を本格採用したことで，確実な金銭回収ルートが技術的に担保された [1]．続く 2015 年頃には，マルウェア開発者が攻撃インフラをパッケージとして提供する RaaS (Ransomware-as-a-Service) の普及により，専門知識を持たない犯罪者でも容易に攻撃を実行可能となった [1]．これにより攻撃は爆発的に増加し，標的も個人から高額な資金を詐取できる企業や重要サーバー，特に Linux サーバー等を狙い撃ちにする標的型攻撃 (Big Game Hunting) へと移行を開始した [2]．

2.1.5 2019 年～現在

2019 年末に登場した Maze を契機として，現代のランサムウェアはデータ窃取を組み合わせた二重脅迫が主流となりつつある [2]．従来の暗号化による可用性侵害にとどまらず，暗号化の実行前の潜伏期間中に，システムから機密データを隠密裏に外部の C&C (Command and Control) サーバーへ持ち出す [2]．そして，身代金を支払わなければデータを暴露サイトで一般公開すると脅迫する．データが一度流出すると，たとえ堅牢なバックアップからシステムを完全に復元できたとしても，社会的信用の失墜や個人情報保護法違反等に伴う巨額のペナルティといった不可逆的な被害を防ぐことができないため，現在の防衛において最も深刻な課題となっている [2]．

2.2 ランサムウェアの分類

ランサムウェアは，標的，感染経路，C&C 通信，悪意のあるアクションの 4 つの軸から体系的に分類される [1]．

2.2.1 標的

初期のランサムウェアは，スパムメール等を用いて不特定多数の個人を狙うばらまき型が主流であったが，現在は巨額の身代金を詐取できる特定の組織やインフラを標的とする標的型 (Big Game Hunting) が主流である [6]．標的プラットフォームは長らく Windows OS 搭載の PC・ワークステーションが主流であったが，近年では企業のコアインフラである Linux サーバー，Android 等のモバイルデバイス，さらにはスマートファクトリー等における IoT/CPS（サイバー物理システム）デバイス，クラウドストレージやデータベースにまでその攻撃範囲を拡大している [2]．

2.2.2 感染経路

侵入経路としては，PDF や DOC 等の正規オフィスドキュメントに擬装した実行ファイルを送付するフィッシングメールが依然として支配的である [6]．次いで，開示された RDP (Remote Desktop Protocol) の脆弱性悪用，OS やブラウザ，サーバー用ソフトウェアの未パッチの脆弱性，改ざんされた正規 Web サイトに隠蔽されたスクリプトを介して自動ダウンロードさせるドライブバイダウンロード等が挙げられる [1]．

2.2.3 C&C 通信

多くの暗号型のランサムウェアは，暗号鍵（セッション鍵）の交換や端末情報のアップロードのために外部の C&C サーバーと通信する [1]．通信方式には，検体内に直接記述されたハードコードされた IP アドレスを叩く静的なアプローチと，検知回避や耐障害性を高めるために DGA (Domain Generation Algorithms) を用いて動的に生成されたドメインと通信する手法が存在する [1]．なお，DGA では日時やシード値等に基づいて多数の候補ドメインを自動生成するため，防御側が特定の C&C ドメインを遮断しても別のドメインへ切り替えることができ，C&C インフラの耐障害性や検知回避性を高める．

2.2.4 悪意のあるアクションとファイル破壊挙動

悪意のあるアクションはロックと暗号化に大別される [6]．ロックは，OS の機能（CreateDesktop API 等）を悪用して

© 2026 Information Processing Society of Japan

画面全域に警告（ランサムノート）を表示し操作を遮断するスクリーンロックや，偽の法執行機関を装ってブラウザを占拠するブラウザロック，さらにはOS自体のロードを妨げるためにMBR (Master Boot Record) の改ざんを行うものが存在する [1]．さらに，Windowsシステムが提供するファイル復元機能（シャドウコピー）を無効化するため，多くの検体は感染直後にシステムコマンド（vssadmin.exe Delete等）を実行し，被害者側でのバックアップによる復旧を組織的に遮断する [1]．

2.3 キルチェーンの段階的プロセス

ランサムウェア攻撃は，一般に図2に示すとおり，以下の6つの段階からなるキルチェーンに従って進行する [6]．

まず，配布 (Distribution) 段階では，フィッシングメールやWebインジェクション等を用いて標的端末へ検体を配送する．次の感染 (Infection) 段階では，標的システム上に検体を展開し，管理者権限を掌握するための特権昇格を行う．続くステージング (Staging) 段階では，レジストリ値の変更等によって永続化を確立するとともに，C&Cサーバーへの接続や暗号鍵の交換を実施する．その後，スキャン (Scanning) 段階において，ローカルドライブ，ネットワーク共有フォルダ (NAS)，接続されたクラウドストレージ内から暗号化対象ファイルを探索する．暗号化 (Encryption) 段階では，検体にハードコードされた暗号鍵，またはC&Cサーバーから取得した暗号鍵を用いて，対象ファイルを高速に暗号化する．最後に，支払い (Payment) 段階では，システム上にランサムノートを表示し，暗号資産を用いた身代金の支払いを要求する．

3. 機械学習・深層学習によるランサムウェア検知

ランサムウェア攻撃が高度化・多様化する中，従来のシグネチャ（ハッシュ値や既知の静的パターン）に基づく検知手法では，ゼロデイ攻撃やパッキング，難読化を施された亜種を検知することが困難となっている [1]．これを打破するため，図3に示すとおり，プログラム実行時の振る舞いを分析する動的解析と，そこから得られる特徴空間を学習する機械学習 (ML) および深層学習 (DL) モデルの適用が現在の防衛研究の主流となっている [7]．

3.1 静的解析と動的解析の技術的ポジショニング

検知モデルを構築するためのプログラム解析手法は，大きく静的解析と動的解析に大別される [7]．

3.1.1 静的解析

静的解析は，検体を実行することなくPE (Portable Executable) ヘッダ情報やバイナリ内の `strings`（平文文字列），逆アセンブルされたOpcode（オペコード）シーケンスを走査するため高速である [1]．しかし，攻撃者がエンコードや難読化ツール，商用のパッカーを適用するだけで，シグネチャや静的特徴空間は容易に破壊される [3]．

3.1.2 動的解析

動的解析は，サンドボックス等の隔離された仮想環境において検体を実際に稼働させ，OSやカーネルと交わされるシステムコールの挙動を直接監視する [7]．検体が実行時に自己解凍（アンパック）を行ってメモリ上に真のコードを展開した後の挙動を捕捉するため，高度な難読化に対しても高い頑健性を示す [7]．しかしながら，仮想環境を検知して実行を一時休止するサンドボックス回避挙動（パラノイア活動）への対応や，解析プロセスのオーバーヘッド，および一定時間の稼働監視に伴う検知の遅延が実運用上の大きなボトルネックとなる [2]．

3.2 特徴量設計と検知特徴空間

機械学習モデルに学習させる検知特徴量の選択は，モデルの検知精度および検知遅延を直接左右する．文献調査 [1] に基づく，PC・ワークステーション向けランサムウェア検知で用いられる主要特徴量と，その技術的意義を以下に整理する．

- **API・システムコール**
  ランサムウェアがOSから提供される暗号化サブシステムやファイルシステムにアクセスするための要求を表現するもので，最も頻繁に用いられる特徴量である [1]．特にファイルの列挙 (`FindFirstFile`, `FindNextFile`) や，ファイルのオープン・書き換え (`CreateFile`, `WriteFile`) 等の特定のAPIシーケンスは，早期検知に重要な特徴空間を構成する [7]．

- **ファイルシステム・ディレクトリ操作**
  特定の時間窓内におけるファイル読み書き操作のバースト性や，作成・削除・移動の頻度を監視する [1]．ファイルの大量オープンや，オリジナルファイルの削除等はランサムウェアの証拠（レッドフラグ）となる [7]．

- **レジストリ操作**
  システム再起動後もマルウェアを自律起動させる永続化のためのスタートアップレジストリキーの改ざんや，システムのセキュリティ設定（UAC等の無効化）を監視する [1]．

- **エントロピー**
  ファイル書き換え時におけるデータの無秩序さ（情報エントロピー）の変化を捉える手法である [1]．プレーンテキストや正規のデータ形式が暗号化されると，そのエントロピーは最大値（理論値8.0に近い値）へと急増する [2]．ただし，正規の圧縮処理やBenignな暗号化通信との区別が困難なため，通常は補助的な特徴量として利用される [1]．

© 2026 Information Processing Society of Japan

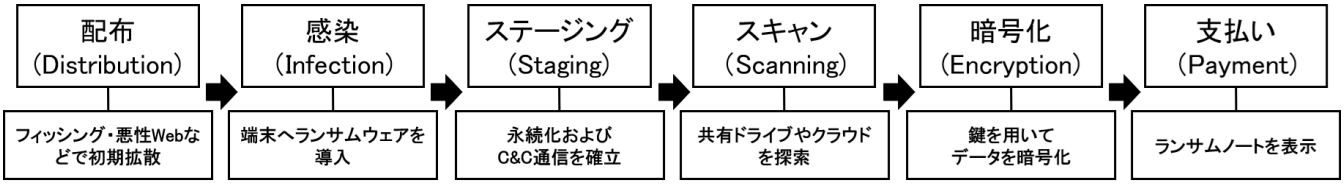


図 2: ランサムウェアのキルチェーン

- **ネットワークトラフィックフロー**
  C&C サーバーとの間のパケットサイズ，接続ポート，プロトコル (HTTP/HTTPS,TCP/UDP)，および DNS クエリの発生パターンを監視し，不正な鍵交換通信や持ち出しプロセスの初期動作を捕捉する [2].

3.3 ML/DL アルゴリズムによる検知の現状

ランサムウェア防衛研究の大半が検知に焦点を当てており，その実証研究では機械学習 (ML)・深層学習 (DL) モデルを採用している [1]．実証研究における採用例では，従来型機械学習 (ML) が最も多く，次いで深層学習 (DL) が用いられている [1]．動的解析と ML/DL による早期検知について図 3 に示す．さらに，各モデルの技術的特性と適用実績を以下に詳述する．

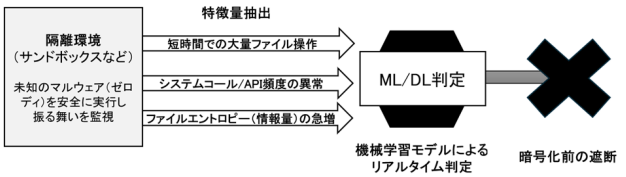


図 3: 動的解析と ML/DL による早期検知

3.3.1 従来型機械学習 (ML)

従来型 ML は，特徴量が人間の手によって事前に設計（ハンドクラフト）されている場合に威力を発揮し，比較的軽量な学習・推論コストで高い分類精度を達成できるため，エンドポイントでのリアルタイム検知に適している [3].

- **サポートベクターマシン（SVM）**
  高次元で非線形分離が必要な API 呼び出し履歴やシステムコールの境界決定において，最適なマージン最大化超平面を決定するアプローチとして広く用いられる [1].

- **ランダムフォレストおよび決定木**
  複数の決定木を組み合わせるアンサンブル学習であるランダムフォレストは，高次元データに対する過学習を防ぎ，特徴量の重要度（Gini 重要度等）を定量的に評価できることから，検知精度と説明性のバランスに最も優れたアプローチとして多用されている [3].

- **その他（kNN，Naive Bayes 等）**
  ネットワークフローの類似度計算には計算コストの低い k-NN，事前確率に基づきスパムやマルウェアを迅速にクラス分けするには Naive Bayes が，それぞれ適材適所で活用される [1].

3.3.2 深層学習（DL）

深層学習は，人間が明示的に特徴量を設計することなく，高次元で時系列的な生データ (Raw data) から複雑な相互依存関係や攻撃シーケンスの潜在特徴を自律的に抽出・学習することに優れている [7].

- **RNN とその発展モデル (LSTM)**
  API コールやシステムコールでは，時間的な前後関係（コンテキスト）が重要である．RNN (Recurrent Neural Network) は時系列的な依存関係の学習に用いられ，特にその一種である LSTM (Long Short-Term Memory) は長期依存関係の学習に適している．このため，攻撃シーケンスの時系列的特徴を捉え，ステルス動作を検出するための有力なモデルとなる [1].

- **その他のニューラルネットワーク**
  MLP (Multi-Layer Perceptron) による特徴ベクトルの非線形マッピングや，Opcode シーケンスをグレイスケール画像に変換して畳み込み CNN (Convolutional Neural Network) で画像分類問題として捉えるアプローチ等も開拓されている [7].

これらの AI 技術により，暗号化処理の開始前またはごく初期の段階でランサムウェアの挙動を検出し，被害拡大前に遮断する早期検知技術が研究されている [7].

4. 動的解析と暗号鍵の脆弱性を突く復旧技術

万が一，前章までに述べた機械学習等による早期検知・防御網を突破され，システム内で暗号化プロセスが開始されてしまった場合，身代金を支払うことなく被災データを救出する復旧が最終的な防衛ラインとなる．本章では，ランサムウェアが採用する暗号メカニズムの隙を突き，プロアクティブに暗号鍵を特定・回収する 2 つの先進的な復旧アプローチについて，技術的な実装ロジックを解説する．

4.1 ハイブリッド暗号の隙を突くセッション鍵のフッキング (PayBreak)

現代のほぼすべての暗号型ランサムウェアは，ファイル

© 2026 Information Processing Society of Japan

の高速な暗号化と復号の困難性を両立させるため，ハイブリッド暗号システムを採用している [4]．これは，まず被害端末のローカル内で生成した一時的な対称鍵（セッション鍵：AES や ChaCha20 等）を用いてファイルを高速に一括暗号化し，その後，その対称鍵自体を攻撃者の所有する非対称暗号の公開鍵（RSA 等）で暗号化して C&C サーバーへ送出，あるいはローカル上に保存する仕組みである [4]．

適切な鍵長と安全な実装を前提とした場合，非対称暗号でカプセル化されたセッション鍵を，攻撃者の秘密鍵なしに現実的な計算時間で復号することは計算量的に困難である．しかし，防衛側から見れば暗号化を実行する瞬間に，セッション鍵は平文の状態で被害端末のメモリ (RAM) 上，あるいは暗号化ライブラリの API 引数に必ず存在しなければならない脆弱性が存在する．

この脆弱性を突くプロアクティブな防衛アーキテクチャが, Kolodenker らによって開発された PayBreak である [4]．PayBreak は，OS が提供する標準的な暗号化 API（Windows における Microsoft CryptoAPI 等）の呼び出しを動的にフックする常駐型エージェントとして動作する [4]．

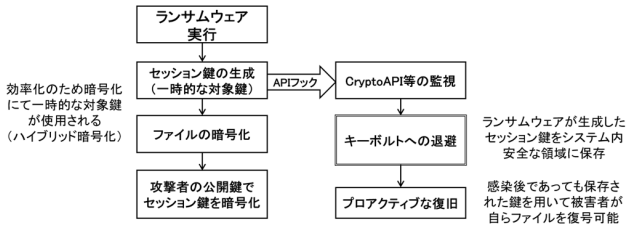


図 4: PayBreak によるセッション鍵の傍受

図 4 に示すとおり，ランサムウェアがファイルの暗号化に向けてセッション鍵を生成する際，PayBreak はフッキング機構によって生成されたセッション鍵の平文パラメータを横取りする [4]．そして，その鍵を，システムの安全な領域に設置された，独自の公開鍵で二重に保護された暗号化キーボルトへと安全に保管する [4]．

攻撃者はプロセスを完了してランサムノートを提示するが，防衛側はキーボルトからセッション鍵を抽出することで，攻撃者の秘密鍵に依存することなく，暗号化された全ファイルを自力で完全に復号・復旧することが可能となる [4]．実証実験では，CryptoLocker を含む 20 種類の実世界のランサムウェアファミリーに対して完全なデータ復旧が実証されており，システムパフォーマンスへのオーバーヘッドも軽微であることが報告されている [4]．

4.2 疑似乱数生成器の分析と鍵の推測

ランサムウェアが強力な暗号鍵を生成するためには，高い情報エントロピーを持つ予測不能な乱数源が必要となる．しかし，ランサムウェアの鍵取得戦略に関する包括的なセキュリティ分析 [5] により，多くのマルウェアの実装において鍵の生成・管理部分に技術的脆弱性が存在することが明らかになっている．

例えば，OS が提供する暗号学的に安全な擬似乱数生成器 (CSPRNG: Cryptographically Secure Pseudo-Random Number Generator) を使用せず，暗号学的に安全でない PRNG (Pseudo-Random Number Generator) を鍵生成に使用しているランサムウェアが多々確認されている [5]．さらに，乱数生成のシード値として，システム起動時間や，ミリ秒単位のシステム時刻等，攻撃実行時に外部から容易に予測・絞り込み可能なパラメータに依存している実装不備が散見される [5]．

このような脆弱性が存在する場合，防衛側は検体のファイル作成日時等のログからランサムウェアの実行時刻を特定し，その時間内でシード値を総当たりすることで，生成された乱数系列を完全に再構成できる [5]．これにより，攻撃者から復号鍵を購入することなくセッション鍵を数学的に特定し，復元プログラムを動的に開発して被災データを復号・復旧することが可能となる [5]．

5. データ持ち出し時代における課題と展望

これまでに述べた機械学習を用いた動的検知や，API フックによる鍵傍受技術（PayBreak 等）は，個々のエンドポイントにおけるファイルの暗号化阻止において優れた成果を収めてきた．しかし，ランサムウェアの攻撃パラダイムが二重脅迫（データ持ち出し）へと大きくシフトしているため，これまでの防御モデルの延長線上では本質的な解決に至らない技術的限界がある [2]．本章では，現代のランサムウェア防御が直面している主要な課題を整理し，未来に向けた技術的・組織的なロードマップを提示する．

5.1 暗号化阻止からデータ持ち出し対策へのシフト

近年のランサムウェア関連論文の大部分は，依然としてファイルの暗号化プロセスの阻止に焦点を当てて研究開発を継続している [2]．

しかし，実際の攻撃シーケンスは二重脅迫が主流となっている [2]．攻撃者はファイルの暗号化を実行する前の潜伏期間中に，価値ある知的財産や個人情報等の機密データを外部の C&C サーバー等へ盗み出す [2]．一度でも機密データが境界網を越えて流出してしまえば，その後どれほど強固な検知モデルで暗号化をミリ秒単位で阻止したとしても，情報漏洩の暴露による社会的信用の失墜を回避することはできない [2]．

したがって，今後の学術研究および製品開発においては，特徴量として API コールやファイルシステムのエントロピーだけを監視するアプローチから，不審なネットワーク通信，不正なデータ圧縮処理，境界外への大容量のデータ転送といったデータ持ち出しプロセスそのものを早期に検知・遮断する仕組みの確立が急務である [2]．

© 2026 Information Processing Society of Japan

5.2 AI 防衛モデルにおける概念ドリフトと敵対的機械学習への対抗

3 章で述べた機械学習 (ML) および深層学習 (DL) による検知モデルを実運用するにあたり，回避が困難な 2 つの固有の技術的課題が存在する [1].

(1) **概念ドリフト**
時間の経過や攻撃インフラのアップデートに伴い，マルウェアの攻撃パターンや正常ファイルの動作特性が変化し，過去の静的なデータセットで訓練された ML モデルの検知精度が著しく低下する現象である [1].

(2) **敵対的機械学習**
攻撃者が AI の識別ロジックを再構成し，検知を回避するよう設計された回避攻撃や，学習フェーズで悪意あるデータを混入させるポイズニング攻撃を仕掛ける技術である [3]．例えば，攻撃者がランサムウェアの動作シーケンスの中に，無害な正規アプリのシステムコールを多数挿入することで，AI に無害なソフトウェアと誤認させるテクニックが実証されている [8].

これらの課題に対抗するためには，図 5 に示すとおり，単一の学習済モデルを静的に適用し続けるのではなく，Generative Adversarial Network (GAN) 等の生成モデルを用いて未知の回避パターンのシミュレーションデータを自律的に生成し，事前に AI モデルの堅牢性を高める敵対的トレーニング技術の開発が不可欠である [1].

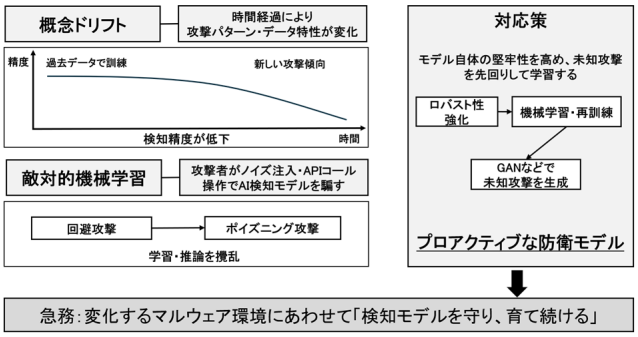


図 5: 概念ドリフトと敵対的機械学習への対応

5.3 実践的な防衛ロードマップ

進化を続けるランサムウェアの脅威に対し，単一のエンドポイント技術（検知 AI や API フック）で完全な防御を達成することは実質的に不可能である．したがって，未来のロードマップは，システムが感染し，境界を突破されることを前提とした，レジリエンス（強靭性）重視の多層防御へと移行しなければならない.

5.3.1 マイクロセグメンテーション

技術的な具体策の筆頭として，ネットワーク内部における横展開（ラテラルムーブメント）を即座に封じ込めるマイクロセグメンテーション技術の動的強制が挙げられる．これにより，特定の端末や仮想サーバーがランサムウェアに感染した場合でも，セグメント間の通信をゼロトラストポリシーに基づき自律的に遮断し，企業ネットワーク全体や Linux コアサーバーへの被害拡大を物理的・論理的に防止する．実装方式としては，ホストベースの分散ファイアウォールやソフトウェア定義ネットワーク (SDN) を用い，アプリケーションやワークロード単位で通信許可ポリシーを適用する方式がある．こうした機能を実装した商用製品も存在し，物理・仮想・クラウド環境をまたいでワークロード間通信を可視化・制御することで，侵害端末からのラテラルムーブメントを抑制している.

5.3.2 戻せるバックアップ

さらに，感染後の最終防衛ラインとして，検証可能な戻せるバックアップの確立が必要である．従来のバックアップは前日のデータに戻すといった単純なロールバックに依存していたが，潜伏期間の長い現代のランサムウェアはバックアップデータ自体を汚染（ポイズニング）しているか，あるいは感染開始時期の特定が困難である．そのため，バックアップデータの不変性を担保するとともに，複数世代の復旧ポイントを保持し，感染時点より前の健全性を確認できる復旧点を選択可能とする仕組みが必要となる．さらに，バックアップ自体が侵害される可能性を考慮し，オフライン化や論理的隔離，整合性検証を組み合わせたバックアップレジリエンスが重要となる.

5.3.3 ガバナンス・リスク・コンプライアンス

これらの高度な防衛技術は，図 6 に示すとおり，組織全体のセキュリティガバナンス，インシデント対応体制，データ保護規制への適合を包含するガバナンス・リスク・コンプライアンス (GRC) フレームワークにタイムリーに統合されなければならない [1]．技術・人・プロセスがオーケストレーションされ，リスクマネジメントと密接に連動して初めて，絶え間なく変化するランサムウェアの猛威から社会的な重要インフラを保護することが可能となる [2].

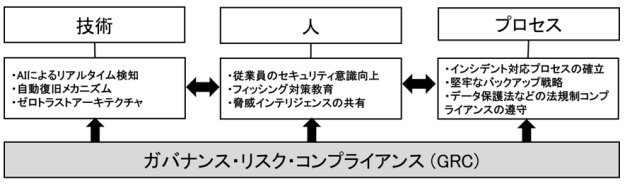


図 6: セキュリティリスク管理（GRC）の統合

6. 防衛側と攻撃者の対応

実効的なランサムウェア対策には，多段階の攻撃キルチェーンに即した多層防御が必要である．本章では，図 7 に示すとおり，対策を攻撃自体の防御（侵入防止・暗号化防止）と被害の影響の最小化（持ち出し検出・横展開抑制・

© 2026 Information Processing Society of Japan

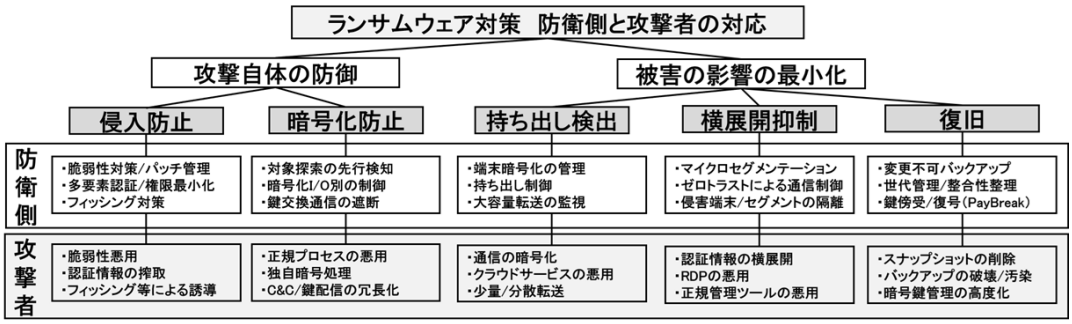


図 7: 防衛側と攻撃者の対応

復旧）の 2 つのアプローチに大別し，防衛側と攻撃者の技術的な対応関係を整理する．

まず，攻撃自体の防御に含まれる侵入防止では，脆弱性悪用やフィッシングに対し，迅速なパッチ管理，多要素認証 (MFA)，特権最小化により境界を保護する．続く暗号化防止では，攻撃者が検知回避のために OS 標準の正規プロセスを悪用するのに対し，ファイル変更の I/O 制御，スキャンの先行検知，および C&C 通信の動的遮断によって暗号化動作を未然に阻止する．

次に，被害の影響の最小化に含まれる持ち出し検出では，クラウドの悪用や少量・分散転送による暗号化前のデータ窃取に対し，転送量だけでなく，通信先，転送頻度，時間帯等を含むネットワーク通信の継続的な監視によって対抗する．横展開抑制では，RDP や正規管理ツールの悪用による感染拡大に対し，マイクロセグメンテーションや侵害セグメントの論理的隔離を強制する．最後の復旧では，攻撃者によるバックアップ破壊やスナップショット削除に対し，変更不可（イミュータブル）バックアップと PayBreak 等の動的鍵傍受技術を統合することで，自力でのデータ復旧を確立する．

7. まとめ

本稿では，1989 年の黎明期から現代の二重脅迫（データ持ち出し）に至るランサムウェアの進化を 5 つの段階に整理した．また，動的解析と ML/DL を用いた早期検知，暗号 API フック（PayBreak），鍵生成の実装脆弱性を突く復旧技術を検討し，防衛技術を体系的に評価した．その結果，実際の攻撃はデータ持ち出し，横展開，復旧妨害を組み合わせる方向へ多段階化・高度化しており，単一のエンドポイント対策のみでは不十分であるという点を明らかにした．

この課題を解決するため，前章で示した侵入防止，暗号化防止，持ち出し防止，横展開抑制，復旧の 5 つの局面を一体化させた，レジリエンス重視の多層防御システムへの移行が必要となる．特に，暗号化前に行われるデータ持ち出しは，暗号化の遮断やバックアップ復旧だけでは解決できないため，データ持ち出し防止策を従来の暗号化防止策と並行して強化することが不可欠となる．

その際，実運用における概念ドリフトや敵対的機械学習に対して検知モデルの堅牢性を継続的に高め，技術・人・プロセスをガバナンス・リスク・コンプライアンス (GRC) フレームワークの下で統合し，組織の法規制や事業継続要件と密接に連動させなければならない．攻撃者と防衛側の対応関係を定期的に見直し，多層防御を構成する各対策の有効性と相互補完性を継続的に評価・検証し続けることが，絶え間なく進化するランサムウェアの脅威に対して強靭な組織・社会インフラを実現する重要な要件となる．

参考文献

[1] Harun Oz, Ahmet Aris, Albert Levi, and A. Selcuk Uluagac. A survey on ransomware: Evolution, taxonomy, and defense solutions. *ACM Computing Surveys*, September 2022.

[2] Dongwei McIntosh, Yaqi Hao, Alex Ng, and Malka Halgamuge. Ransomware reloaded: Re-examining its trend, research and mitigation in the era of data exfiltration. *ACM Computing Surveys*, p. Article 18, October 2024.

[3] Amjad Alraizza and Abdulmohsen Algarni. Ransomware detection using machine learning: A survey. *Big Data and Cognitive Computing*, August 2023.

[4] Gianluca Kolodenker and Manuel Egele. Paybreak: Defense against cryptographic ransomware. In *Proceedings of the 2017 ACM on Asia Conference on Computer and Communications Security (ASIA CCS '17)*. ACM, 2017.

[5] Ziya Alper Genç, Gabriele Lenzini, and Peter Y. A. Ryan. Security analysis of key acquiring strategies used by cryptographic ransomware. In *Proceedings of the Central European Cybersecurity Conference 2018 (CECC 2018)*. ACM, November 2018.

[6] Amjad Razaulla, Wathiq Mansoor, Benjamin C. M. Fung, and Chadi Assi. The age of ransomware: A survey on the evolution, taxonomy, and research directions. *IEEE Access*, April 2023.

[7] Umara Urooj, Anazida Al-rimy, Fuad A. Ghaleb, and Murad A. Rassam. Ransomware detection using the dynamic analysis and machine learning: A survey and research directions. *Applied Sciences*, December 2021.

[8] Francesco Cara, Michele Scalas, Giorgio Giacinto, and Davide Maiorca. On the feasibility of adversarial sample creation using the android system api. *Information*, 2020.

© 2026 Information Processing Society of Japan